

SOS

অতি সংক্ষিপ্ত প্রশ্নোত্তর :

**** ১। আইটি অডিট কী?**

উত্তর : একটি প্রতিষ্ঠানের কম্পিউটার সিস্টেম, নেটওয়ার্ক এবং সফটওয়্যারগুলো সঠিকভাবে ও নিরাপদে চলছে কি না, তা একজন বিশেষজ্ঞ (Auditor) দিয়ে পরীক্ষা করানোই হলো আইটি অডিট।

*** ২। আইটি অডিটের মূল লক্ষ্য কী?**

উত্তর : আইটি অডিটের মূল লক্ষ্যসমূহ : সম্পদ সুরক্ষা, তথ্যের অখণ্ডতা বা নির্ভুলতা, সিস্টেমের কার্যকারিতা, সিস্টেমের দক্ষতা, আইন ও নীতিমালার পরিপালন।

***** ৩। স্যাম্পলিং মেথডলোজি(Sampling Methodology) কী?**

উত্তর : স্যাম্পলিং মেথডলোজি হলো একটি পরিসংখ্যানগত প্রক্রিয়া যার মাধ্যমে একটি বিশাল জনগোষ্ঠী বা তথ্যভাণ্ডার থেকে একটি নির্দিষ্ট অংশ বা নমুনা বাছাই করা হয়। এই বাছাইকৃত নমুনার ওপর ভিত্তি করেই পুরো জনগোষ্ঠীর বৈশিষ্ট্য সম্পর্কে একটি ধারণা বা সিদ্ধান্ত নেওয়া হয়।

SOS**সংক্ষিপ্ত প্রশ্নোত্তর :**

* ১। আইটি অডিটিং প্রক্রিয়ার ধাপসমূহ লেখ।

উত্তর : আইটি অডিটিং (IT Auditing) হলো একটি সুশৃঙ্খল প্রক্রিয়া যা ধাপে ধাপে সম্পন্ন করতে হয়। এই প্রক্রিয়াটি নিশ্চিত করে যে একটি প্রতিষ্ঠানের তথ্যপ্রযুক্তি ব্যবস্থা নিরাপদ, দক্ষ এবং নিয়মমাফিক চলছে।

আইটি অডিটিং প্রক্রিয়ার প্রধান ধাপগুলো নিম্নরূপ :

- i) পরিকল্পনা (Audit Planning)
- ii) তথ্য সংগ্রহ ও পর্যবেক্ষণ (Evidence Collection)
- iii) নিয়ন্ত্রণ পরীক্ষা (Testing of Controls)
- iv) বিশ্লেষণ ও মূল্যায়ন (Fieldwork & Analysis)
- v) প্রতিবেদন তৈরি (Reporting)
- vi) ফলো-আপ (Follow-up)

** ২। আইটি অডিট রিপোর্টিং প্রক্রিয়ার ধাপসমূহ আলোচনা কর।

উত্তর : কটি কার্যকর আইটি অডিট রিপোর্টিং প্রক্রিয়া সাধারণত নিচের ধাপগুলোর মাধ্যমে সম্পন্ন হয় :

i) প্রাথমিক পর্যবেক্ষণ বা খসড়া রিপোর্ট তৈরি (Preparation of Draft Report) :

অডিট শেষ করার পর অডিটর প্রথমে একটি খসড়া রিপোর্ট তৈরি করেন। এতে অডিটের উদ্দেশ্য, পরিধি এবং প্রাপ্ত ফলাফলগুলো (Findings)

বিস্তারিতভাবে লেখা থাকে। এটি চূড়ান্ত করার আগে সংশ্লিষ্ট বিভাগের কর্মকর্তাদের সাথে শেয়ার করা হয় যাতে কোনো ভুল বোঝাবুঝি না থাকে।

ii) এক্সিট মিটিং বা আলোচনা (Exit Interview/Meeting) :

খসড়া রিপোর্টটি নিয়ে আইটি ম্যানেজার বা বিভাগীয় প্রধানদের সাথে একটি বৈঠক করা হয়।

উদ্দেশ্য : অডিটর যেসব ত্রুটি পেয়েছেন সেগুলোর সাথে ম্যানেজমেন্ট একমত কি না তা নিশ্চিত করা।

মতামত গ্রহণ : যদি কোনো ত্রুটির পেছনে যৌক্তিক কারণ থাকে, তবে ম্যানেজমেন্ট তা অডিটরকে জানানোর সুযোগ পায়।

iii) ম্যানেজমেন্ট রেসপন্স সংগ্রহ (Gathering Management Responses) :

অডিটর প্রতিটি সমস্যার বিপরীতে ম্যানেজমেন্টের বক্তব্য জানতে চান। ম্যানেজমেন্টকে জানাতে হয় যে তারা সমস্যাটি স্বীকার করছেন কি না। সমস্যা সমাধানের জন্য তারা কী পদক্ষেপ নেবেন। কত দিনের মধ্যে সমস্যাটি সমাধান করা হবে।

iv) চূড়ান্ত রিপোর্ট তৈরি (Final Report Issuance) :

ম্যানেজমেন্টের মতামত যুক্ত করার পর চূড়ান্ত রিপোর্ট তৈরি করা হয়।

একটি আদর্শ রিপোর্টে সাধারণত থাকেঃ সারসংক্ষেপ (Executive Summary) : অটেকনিক্যাল ব্যক্তিদের জন্য অডিটের মূল ফলাফল।

অডিট মেথডোলজি : কোন পদ্ধতিতে অডিট করা হয়েছে।

বিস্তারিত ফলাফল : কোথায় কোথায় নিয়ম ভঙ্গ হয়েছে বা দুর্বলতা আছে।

সুপারিশ (Recommendations) : সমস্যা সমাধানে অডিটরের পরামর্শ।

v) অডিট অপিনিয়ন বা রেটিং (Audit Opinion) :

রিপোর্টের শেষে অডিটর তার পেশাদার মতামত দেন।

এটি সাধারণত তিন ধরনের হতে পারে : **Unmodified (সম্পূর্ণ) :** যদি সিস্টেমটি আইন ও নিরাপত্তা অনুযায়ী সঠিক থাকে।

Qualified (শর্তসাপেক্ষ) : কিছু ছোটখাটো ত্রুটি থাকলে।

Adverse (অসন্তোষজনক) : যদি সিস্টেমে বড় ধরনের নিরাপত্তা ঝুঁকি থাকে।

vi) ফলো-আপ এবং ট্র্যাকিং (Follow-up) :

রিপোর্ট প্রদানের কয়েক মাস পর অডিটর পুনরায় চেক করেন যে সুপারিশগুলো বাস্তবায়ন করা হয়েছে কি না। যদি সমস্যাগুলো থেকে যায়, তবে তা পরবর্তী অডিট সাইকেলে অন্তর্ভুক্ত করা হয়।

**** ৩। আইটি অডিট স্যাম্পলিং মেথডলোজির ধাপ ব্যাখ্যা কর।**

উত্তর : নিচে আইটি অডিট স্যাম্পলিং মেথডলোজির প্রধান ধাপগুলো ব্যাখ্যা করা হলো :

i) অডিটের লক্ষ্য নির্ধারণ (Define the Audit Objective) :

স্যাম্পলিং শুরু করার আগে অডিটরকে স্পষ্ট হতে হয় যে তিনি কী পরীক্ষা করতে চান। যেমনঃ "গত এক বছরে অননুমোদিত কেউ সিস্টেমে লগ-ইন

করার চেষ্টা করেছে কি না তা পরীক্ষা করা।" লক্ষ্য স্পষ্ট না হলে সঠিক নমুনা বাছাই করা সম্ভব হয় না।

ii) পপুলেশন বা জনগোষ্ঠী চিহ্নিতকরণ (Define the Population) :

পপুলেশন হলো সেই সম্পূর্ণ ডেটাসেট যেখান থেকে নমুনা নেওয়া হবে। যেমনঃ যদি কোনো ব্যাংকের ক্রেডিট কার্ড ট্রানজেকশন অডিট করতে হয়, তবে পুরো বছরের সব ক্রেডিট কার্ড ট্রানজেকশন হবে 'পপুলেশন'। অডিটরকে নিশ্চিত করতে হয় যে পপুলেশনটি সম্পূর্ণ এবং প্রাসঙ্গিক।

iii) স্যাম্পলিং ইউনিট নির্ধারণ (Define the Sampling Unit) :

পপুলেশনের ভেতরের কোন ছোট অংশটি একটি একক নমুনা হিসেবে গণ্য হবে তা ঠিক করা। এটি হতে পারে একটি নির্দিষ্ট ফাইল, একটি ট্রানজেকশন আইডি, বা একজন ব্যবহারকারীর লগ-ইন রেকর্ড।

iv) স্যাম্পলিং পদ্ধতি নির্বাচন (Selection of Sampling Method) :

অডিটর কোন পদ্ধতিতে নমুনা বাছাই করবেন তা এই ধাপে ঠিক করা হয়। এটি সাধারণত দুই প্রকারের হয় :

স্ট্যাটিস্টিকাল স্যাম্পলিং : এখানে গণিত বা পরিসংখ্যানের সূত্র ব্যবহার করা হয় (যেমন : রেন্ডম স্যাম্পলিং)।

নন-স্ট্যাটিস্টিকাল স্যাম্পলিং : এখানে অডিটর তার নিজের অভিজ্ঞতা ও বিচারবুদ্ধি ব্যবহার করে গুরুত্বপূর্ণ ফাইলগুলো বাছাই করেন (যেমন : জাজমেন্টাল স্যাম্পলিং)।

v) নমুনার আকার নির্ধারণ (Determine the Sample Size) :

অডিটর কতগুলো নমুনা নেবেন তা এই ধাপে ঠিক করা হয়। নমুনার আকার নির্ভর করে ঝুঁকির মাত্রার ওপর। যদি কোনো সিস্টেমে ঝুঁকির সম্ভাবনা বেশি থাকে, তবে নমুনার আকার বড় হতে হয়। আবার সিস্টেম যদি খুব নির্ভরযোগ্য হয়, তবে ছোট নমুনাতেই কাজ চলে।

vi) নমুনা নির্বাচন ও পরীক্ষা (Selecting and Testing the Samples) :

নির্বাচিত পদ্ধতি অনুযায়ী ডাটাবেস বা সিস্টেম থেকে নমুনাগুলো সংগ্রহ করা হয় এবং সেগুলোর ওপর পরীক্ষা চালানো হয়। যেমনঃ 100 টি রেকর্ড লগ ফাইলের মধ্যে দেখা হয় কতগুলো ফাইলে নিরাপত্তা বিধি লঙ্ঘিত হয়েছে।

vii) ফলাফলের মূল্যায়ন (Evaluate the Results) :

নমুনা পরীক্ষা করে যে ত্রুটিগুলো পাওয়া গেল, সেগুলোকে পুরো পপুলেশনের ওপর প্রয়োগ করে দেখা হয়। যেমনঃ 100টি নমুনার মধ্যে যদি ৫টি ভুল থাকে, তবে ধারণা করা হয় পুরো পপুলেশনে ভুলের হার প্রায় 5%।

viii) উপসংহার ও রিপোর্টিং (Conclusion and Reporting) :

প্রাপ্ত ফলাফলের ভিত্তিতে অডিটর তার চূড়ান্ত সিদ্ধান্ত নেন যে সিস্টেমটি অডিটে পাস করেছে নাকি ফেল করেছে। যদি ভুল বা ঝুঁকির হার গ্রহণযোগ্য মাত্রার চেয়ে বেশি হয়, তবে ম্যানেজমেন্টকে দ্রুত ব্যবস্থা নিতে বলা হয়।

SOS**রচনামূলক প্রশ্নোত্তর :**

**** ১।** আইটি অডিটের বিভিন্ন ধরনের বর্ণনা দাও।

উত্তর : আইটি অডিট (IT Audit) হলো একটি প্রতিষ্ঠানের প্রযুক্তিগত অবকাঠামো এবং নিরাপত্তার একটি বিস্তারিত মূল্যায়ন। প্রতিষ্ঠানের কাজের ধরন এবং প্রয়োজনীয়তার ওপর ভিত্তি করে আইটি অডিটকে কয়েকটি প্রধান ভাগে ভাগ করা যায়।

নিচে আইটি অডিটের বিভিন্ন প্রকারভেদ বর্ণনা করা হলো :

i) সিস্টেম এবং অ্যাপ্লিকেশন অডিট (Systems and Applications Audit) :

এই অডিটটি নির্দিষ্ট কোনো সফটওয়্যার বা অ্যাপ্লিকেশনের ওপর করা হয়। অডিটর যাচাই করেন যে- অ্যাপ্লিকেশনটি নির্ভুলভাবে ডেটা প্রসেস করছে কি না। এর মাধ্যমে কোনো ভুল বা জালিয়াতি হওয়ার সুযোগ আছে কি না। ব্যবহারকারীদের অ্যাক্সেস লেভেল (Access Level) ঠিকমতো সেট করা আছে কি না।

ii) তথ্য সুরক্ষা বা সাইবার সিকিউরিটি অডিট (Information Security Audit) :

এটি বর্তমানে সবচেয়ে গুরুত্বপূর্ণ অডিট। এর লক্ষ্য হলো প্রতিষ্ঠানের নেটওয়ার্ক ও ডেটা কতটা নিরাপদ তা যাচাই করা।

ফায়ারওয়াল ও অ্যান্টিভাইরাস : এগুলো আপডেট আছে কি না তা দেখা।

পেনিট্রেশন টেস্টিং : হ্যাকাররা যেভাবে সিস্টেমে ঢোকার চেষ্টা করে, সেভাবে কৃত্রিম আক্রমণ চালিয়ে দুর্বলতা খুঁজে বের করা।

iii) সিস্টেম ডেভেলপমেন্ট অডিট (Systems Development Audit) :

যখন কোনো প্রতিষ্ঠান নতুন কোনো সফটওয়্যার তৈরি করে বা সিস্টেম আপগ্রেড করে, তখন এই অডিট করা হয়। অডিটর দেখেন যে সফটওয়্যার তৈরির প্রতিটি ধাপে সঠিক নিরাপত্তা ও কোডিং স্ট্যান্ডার্ড বজায় রাখা হয়েছে কি না। সিস্টেমটি চালুর আগে পর্যাপ্ত টেস্টিং করা হয়েছে কি না।

iv) আইটি ম্যানেজমেন্ট এবং অবকাঠামো অডিট (IT Management & Infrastructure Audit) :

এই অডিটে আইটি বিভাগের সামগ্রিক পরিচালনা পদ্ধতি পরীক্ষা করা হয়। ডাটা সেন্টারের তাপমাত্রা, বিদ্যুৎ ব্যবস্থা এবং হার্ডওয়্যার রক্ষণাবেক্ষণ ব্যবস্থা দেখা। আইটি কর্মীদের প্রশিক্ষণ এবং তাদের কাজের নিয়মাবলি বা এসওপি (SOP) যাচাই করা।

v) বিজনেস কন্টিনিউটি এবং ডিজাস্টার রিকভারি অডিট (BCP & DR Audit) :

বড় কোনো দুর্ঘটনার পর (যেমন-সার্ভার ধ্বংস হওয়া বা হ্যাকিং) প্রতিষ্ঠান কত দ্রুত আবার সচল হতে পারবে, তা এই অডিটের মাধ্যমে পরীক্ষা করা হয়।

ব্যাকআপ : নিয়মমতো ডেটা ব্যাকআপ রাখা হচ্ছে কি না।

রিকভারি টেস্ট : ব্যাকআপ থেকে ডেটা আসলেই ফিরিয়ে আনা যায় কি না তার ড্রিল বা পরীক্ষা করা।

vi) কমপ্লায়েন্স অডিট (Compliance Audit) :

প্রতিষ্ঠানটি আন্তর্জাতিক বা রাষ্ট্রীয় আইন মেনে চলছে কি না তা এই অডিটে দেখা হয়।

যেমন : ব্যাংকগুলোর জন্য PCI-DSS (ক্রেডিট কার্ড সুরক্ষার নিয়ম) বা স্বাস্থ্য খাতের জন্য HIPAA অডিট। বাংলাদেশে ডিজিটাল নিরাপত্তা আইন মেনে চলা হচ্ছে কি না তাও এর অংশ হতে পারে।

*** ২। অডিটিং ইনফরমেশন সিস্টেমের বর্ণনা দাও। বাকশিবো - ২০২৫

উত্তর : নিচে অডিটিং ইনফরমেশন সিস্টেমের বিস্তারিত বর্ণনা দেওয়া হলোঃ

১. মূল উপাদানসমূহ (Core Components) : অডিটিং ইনফরমেশন সিস্টেম প্রধানত তিনটি বিষয়ের ওপর আলোকপাত করেঃ

প্রযুক্তি (Technology) : হার্ডওয়্যার, নেটওয়ার্ক, ডেটাবেস এবং অপারেটিং সিস্টেমের নিরাপত্তা পরীক্ষা করা।

প্রক্রিয়া (Process) : ডেটা এন্ট্রি থেকে শুরু করে আউটপুট পর্যন্ত প্রতিটি ধাপের কাজের নিয়মাবলি যাচাই করা।

মানুষ (People) : ব্যবহারকারী এবং সিস্টেম অ্যাডমিনিস্ট্রেটরদের ভূমিকা, অনুমতি (Permissions) এবং সচেতনতা পরীক্ষা করা।

২. অডিটিং ইনফরমেশন সিস্টেমের প্রধান লক্ষ্য :

তথ্য সুরক্ষা (Information Security) : হ্যাকিং, ভাইরাস বা অননুমোদিত প্রবেশ থেকে সিস্টেম কতটা নিরাপদ তা নিশ্চিত করা।

তথ্যের নির্ভুলতা (Reliability) : সিস্টেমে থাকা ডেটা যেন সঠিক থাকে এবং কোনো ভুল বা জালিয়াতির মাধ্যমে পরিবর্তিত না হয়।

কার্যকারিতা (Effectiveness) : সিস্টেমটি কি আসলেই প্রতিষ্ঠানের ব্যবসায়িক কাজে সাহায্য করছে, নাকি এটি অকেজো হয়ে পড়ে আছে?

আইনি পরিপালন (Compliance) : সরকারি ডিজিটাল নিরাপত্তা আইন বা আন্তর্জাতিক মানদণ্ড (যেমন- ISO 27001) মেনে চলা হচ্ছে কি না।

৩. অডিটিং ইনফরমেশন সিস্টেমের প্রকারভেদ -এটি মূলত দুই ভাবে করা হয় :

Around the Computer : এখানে কম্পিউটার সিস্টেমের ভেতরে কী ঘটছে তা না দেখে কেবল ইনপুট এবং আউটপুট মিলিয়ে দেখা হয়। এটি সাধারণ হিসাবরক্ষণের মতো।

Through the Computer : এখানে সিস্টেমের ভেতরের সফটওয়্যার লজিক, কোডিং এবং ডেটা প্রসেসিং ধাপগুলো সরাসরি পরীক্ষা করা হয়। এটি আধুনিক এবং অধিক নির্ভরযোগ্য পদ্ধতি।

৪. অডিট প্রক্রিয়া (Audit Process) অডিটিং ইনফরমেশন সিস্টেম সাধারণত নিচের ধাপগুলো অনুসরণ করে :

স্কোপ নির্ধারণ : কোন কোন অ্যাপ্লিকেশন বা নেটওয়ার্ক অডিট করা হবে তা ঠিক করা।

ঝুঁকি মূল্যায়ন : কোন কোন জায়গায় দুর্বলতা থাকতে পারে তা চিহ্নিত করা।

কন্ট্রোল টেস্টিং : পাসওয়ার্ড পলিসি, ফায়ারওয়াল এবং ব্যাকআপ সিস্টেম ঠিকমতো কাজ করছে কি না তা পরীক্ষা করা।

রিপোর্টিং : প্রাপ্ত ত্রুটিগুলো নিয়ে একটি চূড়ান্ত প্রতিবেদন তৈরি করা এবং সমাধানের পরামর্শ দেওয়া।